

USDA Cyber Supply Chain Risk Management (C-SCRM) Contract Language

Version 1.0

Approved: Nov 04, 2020

Document Control Information

Version #	Author	Revision Date	Approval Date	Description of change
1.0	ISC SMD	10/28/2020	11/04/2020	Initial Document

The information contained herein is property of USDA OCIO. Unauthorized reproduction or disclosure of this information in whole or in part is prohibited. Limit distribution accordingly

Table of Contents

1	USDA CYBER SUPPLY CHAIN RISK MANAGEMENT (C-SCRM).....	4
1.1	USDA SCRM Policy.....	4
1.2	USDA Supply Chain Risk Review Team.....	5
1.3	C-SCRM Methodology.....	5
2	COUNTRY OF ORIGIN (COO).....	6
3	PERSONNEL AND CERTIFICATION REQUIREMENTS	7
3.1	Personnel	7
3.2	Cybersecurity Certification and Training	9
4	INFORMATION AND COMMUNICATIONS TECHNOLOGY (ICT) SUPPLY CHAIN RISK MANAGEMENT (SCRM) SOFTWARE DEVELOPMENT LIFECYCLE (SDLC)	10
4.1	Continuous Diagnostic and Mitigation (CDM) Approved Products List (APL) Supply Chain Risk Management Plan.....	11
4.2	SCRM Plan Submittal and Review	12
4.3	Manufacturing (Original Equipment Manufacturer (OEM))	13
4.4	End of Life/Support Products.....	13
4.5	Transport/Shipping	16
4.6	Pre-Deployment.....	16
4.7	Deployment.....	16
4.8	Operation and Maintenance.....	16
4.9	Return USDA Government Furnished Property	17
5	ALL-INCLUSIVE AREAS WITHIN ICT SCRM SDLC	17
5.1	Chain of Custody	17
5.2	Tamper Resistance and Detection	18
5.3	Incidents.....	18
5.4	Vulnerabilities	19
5.5	USDA’s Audit Rights	20
5.6	Covered Telecommunication Equipment or Services (Section 889(a)(1)(B))	20
5.7	Environmental Risks.....	21
6	APPENDICES	22
6.1	[Contractor/Sub-Contractor] Cybersecurity Policy / System Security Plan	22
6.2	Cybersecurity & Supply Chain Risk Management (SCRM) References	22
6.3	DEFINITIONS.....	24
6.4	Acronyms and Abbreviations	26

1 USDA CYBER SUPPLY CHAIN RISK MANAGEMENT (C-SCRM)

Cyber Supply Chain Risk Management (C-SCRM) is the process of taking strategic steps to identify, assess and mitigate supply chain risk to departmental and agency information systems, system components and associated services based on analysis of the criticality of system components, services and functions. It covers the entire life cycle of a system (including design, development, distribution, deployment, acquisition, maintenance, and destruction) as supply chain threats and vulnerabilities may intentionally or unintentionally compromise information technology (IT) systems with operational technology (OT) systems (IT/OT) product or service at any stage.

IMPORTANT:

- **Program offices/CORs shall ensure the appropriate Cybersecurity SCRM language is included in requirements documents (PWS, SOW, SOO) and incorporated into the resultant contract action.**
- **The content of this document is applicable to IT or security related contracts.**

C-SCRM contract language is in support the latest publication of:

- [USDA DR 3540-003](#) – *USDA Security Assessment and Authorization (A&A) Policy*,
- [Federal Acquisition Supply Chain Security Act 2018](#),
- [NIST SP 800-161](#) - *Supply Chain Risk Management Practices for Federal Information Systems and Organizations*,
- [NIST SP 800-37](#) - *Risk Management Framework for Information Systems and Organizations*,
- [NIST Cyber Supply Change Risk Management Program](#),
- [NIST SP 800-39](#), *Managing Information Security Risk and*,
- [NIST 800-88](#) - *Guidelines for Media Sanitization*.

1.1 USDA SCRM Policy

In line with its federal obligations, the United States Department of Agriculture (USDA) commits itself through the IT Security Strategy and the Information Security Program (SSISP) Policy (in draft) to develop a Supply Chain Risk Management (SCRM) capability to address supply chain risk. USDA SCRM strategy is based on external and organizational requirements and constraints (e.g., applicable laws and regulations). Policies include the purpose and applicability, as well as investment and funding requirements, of any SCRM program.

Based on the USDA supply chain policy, the SCRM identifies:

- Mission/business requirements that will influence SCRM, such as cost, schedule, performance, security, privacy, quality, and safety;
- Information security requirements, including SCRM-specific requirements;
- Organization-wide mission/business functions and how SCRM will be integrated into their processes;
- Risk tolerance level for supply chain risks;
- A group of individuals across the USDA organization who will address SCRM throughout the organization, known as the USDA SCRM Team; and
- Ensure that SCRM is appropriately integrated into the organization risk management policies and activities.

1.2 USDA Supply Chain Risk Review Team

Implementing SCRM requires organizations establish a coordinated team-based approach to assess supply chain risk and manage this risk by using programmatic and technical mitigation techniques. The coordinated team approach will enable agencies to conduct a comprehensive analysis of their supply chain, communicate with external partners/stakeholders, and gain broad consensus regarding appropriate resources for SCRM. Details of SCRM Review Team roles and responsibilities are contained in USDA's SCRM Strategy document [\[Link\]](#).

The SCRM Review Team should consist of members with diverse roles and responsibilities for leading and supporting SCRM activities including information technology, information security, contracting, risk executive, mission/business, legal, supply chain and logistics, acquisition and procurement, and other relevant functions. These individuals may include government personnel or prime [Contractors/Sub-Contractors] hired to provide acquisition services to a government client. Members of the SCRM Review team should be a diverse group of people who are involved in the various aspects of the Software Development Lifecycle (SDLC). Collectively, to aid in SCRM, these individuals should have an awareness of, and provide expertise in organizational acquisition processes, legal practices, vulnerabilities, threats, and attack vectors, as well as an understanding of the technical aspects and dependencies of systems. The USDA Supply Chain Team may be an extension of an organization's existing information system risk management or include parts of a general risk management team.

1.3 C-SCRM Methodology

The C-SCRM methodology implements strategies to manage both every day and exceptional risks along the supply chain based on continuous risk assessment with the objective of reducing vulnerability and ensuring continuity. The below sections outline USDA's C-SCRM methodology.

Section 2: Country of Origin (COO) represents the country or countries of manufacture, production, design, or brand origin

Section 3: Personnel and Certification Requirements

- Personnel
- Certification and Training

Section 4: Information and Communications Technology (ICT) Supply Chain Risk Management (SCRM) Software Development Lifecycle (SDLC) phases:

- Manufacturing (Original Equipment Manufacturer)
- Transport/Shipping
- Pre-Deployment
- Deployment
- Operation and Maintenance
- Disposition/Return of Government Furnished Property

Section 5: All-Inclusive Areas within the ICT SCRM SDLC:

- Chain of Custody
- Anti-Tampering

- Identified Incidents
- USDA Audit Rights

2 COUNTRY OF ORIGIN (COO)

Country of Origin (COO) represents the country or countries of manufacture, production, design, or brand origin. The expectation is: (1) the cargo is what it purports to be and in the quantity stated; (2) the cargo was in the continuous possession or control by the carrier who took charge of the cargo from the time it was loaded in the container at origin until the time it is delivered at final destination; and (3) there is evidence of the identify of each person or entity who had access to it during its movement and that the cargo remained in the same condition from the moment it was sealed in the container for transfer to the carrier who controlled possession until the moment that carrier released the cargo into the receipted custody of another.

Country of Origin guidelines are as follows:

- a) USDA will not use any product or its components (including hardware, software, and firmware) that are on the *Department of Commerce Entity List*. This includes countries where the development, manufacturing, maintenance, and service for the product are provided.
- b) [Contractor/Sub-Contractor] shall identify the country (or countries) of origin of the procured product and its components (including hardware, software, and firmware).
- c) [Contractor/Sub-Contractor] will identify the countries where the development, manufacturing, maintenance, and service for the product are provided.
- d) [Contractor/Sub-Contractor] will notify USDA of changes in the list of countries where product maintenance or other services are provided in support of the procured product. This notification shall occur # days prior to initiating a change in the list of countries.
- e) [Contractor/Sub-Contractor] shall ensure that all-source threat and vulnerability information includes any available foreign ownership and control (FOCI) data. This data should be reviewed periodically as mergers and acquisitions, if affecting a supplier, may impact both threat and vulnerability information and therefore SCRM.
- f) [Contractor/Sub-Contractor] shall use trusted channels to ship procured products, such as U.S. registered mail.
- g) [Contractor/Sub-Contractor] shall demonstrate a capability for detecting unauthorized access throughout the delivery processes.
- h) [Contractor/Sub-Contractor] shall demonstrate chain-of-custody documentation for procured products as determined by USDA in its sole discretion and require tamper-evident packaging for the delivery of this product.
- i) [Contractor/Sub-Contractor] shall implement anti-tamper technologies and techniques that provide a level of protection for critical information systems, system components, and information technology products against known related threats including modification, reverse engineering, and substitution.

3 PERSONNEL AND CERTIFICATION REQUIREMENTS

3.1 Personnel

3.1.1 Background Check

As part of the [Homeland Security Presidential Directive \(HSPD\) 12](#), *Homeland Security Presidential Directive 12: Policy for a Common Identification Standard for Federal Employees and Contractors*, each [Contractor/Sub-Contractor] must provide identity documentation, as set forth in the Form (I-9), and the validity of the documentation is certified by at least three other checks incorporated into the ID-Proofing process.

- a) [Contractor/Sub-Contractor] shall comply with the personal identity verification (PIV) policies and procedures established by the Department of Agriculture (USDA) [Directives 4620-002](#) series - *Common Identification Standard for U.S. Department of Agriculture Employees and Contractors*.
- b) Should the results of the PIV process require the exclusion of a [Contractor/Sub-Contractor]'s employee; the Contracting Officer Representative (COR) shall notify the Contracting Officer (CO) in writing.
- c) The [Contractor/Sub-Contractor] must appoint a representative to manage compliance with the PIV policies established by the USDA Directives 4620-002 series and to maintain a list of employees eligible for a USDA LincPass required for performance of the work.
- d) The responsibility of maintaining a sufficient workforce remains with the [Contractor/Sub-Contractor]. Employees may be barred by the Government from performance of work should they be found ineligible or to have lost eligibility for a USDA LincPass. Failure to maintain a sufficient workforce of employees eligible for a USDA LincPass may be grounds for termination of the contract.
- e) The [Contractor/Sub-Contractor] shall insert this clause in all subcontracts when the sub[Contractor/Sub-Contractor] is required to have routine physical access to a federally controlled facility and/or routine access to a federally controlled information system.
- f) The PIV Sponsor for this contract is a designated program point of contact, which in most cases is the COR, unless otherwise specified in this contract.

In addition to meeting the requirements of HSPD-12 for PIV (I and II process), all [Contractor/Sub-Contractor]s requiring routine physical access for Federally-controlled facilities and/or routine access to Federally-controlled information systems must have been successfully identity proofed and successfully adjudicated National Agency Check with Written Inquiries (NACI) or Office of Personnel Management (OPM)/National Security (NS) community background investigation to serve on a USDA contract. Contract personnel must have a minimum of a NACI or higher level of background investigation depending on the Position Sensitivity Designation (PSD).

3.1.2 Position Sensitivity Designations (PSDs)

All positions within USDA are assigned Position Sensitivity Designations (PSDs) based upon the risk/damage an unauthorized disclosure would cause to the Agency and/or National Security. This

includes positions occupied by [Contractors/Sub-Contractors]. The Contracting Officer (CO) and/or Contracting Officer Representative (COR) will identify and assign a Position Sensitivity Designation Code to each position that will be occupied by a [Contractor/Sub-Contractor] in the performance of the contract. The CO/COR will advise the [Contractor/Sub-Contractor] of the assigned designation and investigative requirements at the offset of contract talks. The minimum Public Sector Information (PSI) for a [Contractor/Sub-Contractor] is National Agency Check with Law Enforcement and Credit Check (NACLC). However, based upon the assigned sensitivity code, the minimum level PSI may not meet the requirements and a higher level of investigation and/or Security Clearance may be required. The Contracting Officer Representative (COR) will submit all investigative and/or clearance data to the Physical Security Team (PST) five (5) days prior to the [Contractor/Sub-Contractor]'s first day of work. The PSDs are separated into two categories, Public Trust Positions (Risk) and National Security Positions.

- a) Public Trust Positions: These positions are identified as Low Risk, Moderate Risk, and High Risk. They are numerically identified as 1, 5, and 6, respectively. Each of these designations requires a different PSI and a favorable Suitability Determination. Public Trust Positions do not require Personnel Security Clearances.
- b) National Security Positions: These positions are identified as Non-Critical Sensitive, Critical Sensitive and Special Sensitive. They are numerically identified as 2, 3 and 4, respectively. Each of these designations requires a different PSI and a favorable Security Determination. National Security Positions require a Personnel Security Clearance equal to or higher than the level of Access required performing the duties. The level of Clearance is requested at the time the PSI is submitted.

For Position Sensitivity Designation (PSD) for Contract Employees, the [Contractor/Sub-Contractor] will submit proof of their contract employee's investigative and/or clearance data to the COR five (5) days prior to the [Contractor/Sub-Contractor]'s first day of work.

Only appropriately cleared [Contractors/Sub-Contractors] will be utilized in the performance of this Contract. The Physical Security Team will review all investigated and clearance data submitted by the [Contractor/Sub-Contractor] on behalf of their employees and determine its validity. Should any contract employee be removed for security or suitability reasons, it is incumbent on the Company to provide a replacement that meets or exceeds all PSI and/or Clearance requirements. Any failure of the [Contractor/Sub-Contractor] to comply with the Personnel Security requirements may result in the termination of the [Contractor/Sub-Contractor] and/or Contract for default/cause.

[Contractor/Sub-Contractor] ID credentials will be issued after successful identity proofing of the [Contractor/Sub-Contractor] employee applicant and upon verification of a successfully adjudicated NACI or OPM/NS BI.

For more information about HSPD-12, see <https://hspd12.usda.gov/>.

3.1.3 [Contractor/Sub-Contractor] System Access

The Contracting Officer or Contracting Officer's Representative will work with the project manager and/or supervisor to determine the appropriate security access required by the

Contractor. USDA will ensure access is commensurable with the functions to be performed by utilizing the RBAC (Role-Based Access Concept).

3.1.4 Non-Disclosure Agreement

All [Contractor/Sub-Contractor] and sub[Contractor/Sub-Contractor] cybersecurity personnel must submit a Non-Disclosure Agreement, "Employee/[Contractor/Sub-Contractor] Non-Disclosure Agreement" form, prior to the commencement of any cybersecurity work on the contract. Further, [Contractor/Sub-Contractor] and sub[Contractor/Sub-Contractor] personnel must submit a Non-Disclosure agreement whenever replacement personnel are proposed. Any information provided by the [Contractor/Sub-Contractor] or sub[Contractor/Sub-Contractor] in the performance of this contract or obtained by the government is only to be used in the performance of this contract.

3.1.5 [Contractor/Sub-Contractor] Termination / Resignation

Upon termination, resignation or other event leading to a contract employee leaving duty under this contract, the contract employee is responsible for returning all Government identification, vehicle passes, other Government property or anything considered Government Furnished issued to the employee. Such material shall be returned to the Contracting Officer's Representative. Failure on the part of the employee to return such property may result in the [Contractor/Sub-Contractor]'s liability for all costs associated with correcting the resultant breach in building security. Refer to FAR for specific details.'

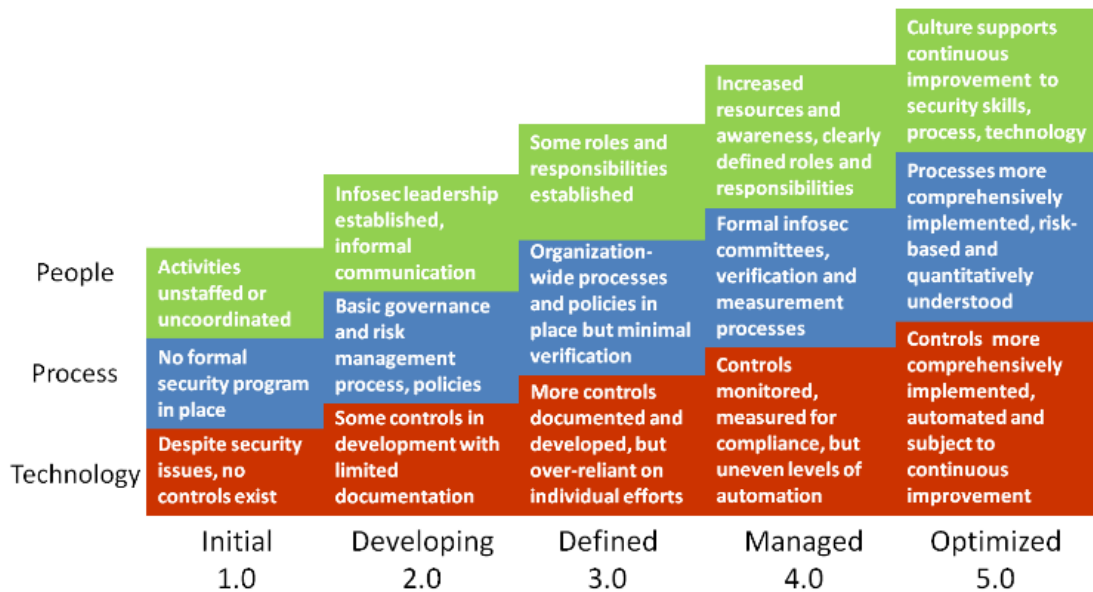
3.2 Cybersecurity Certification and Training

3.2.1 Computing Environment (CE) Certification

The computing environment involves the collection of computer machinery, data storage devices, workstations, software applications, and networks that support the processing and exchange of electronic information demanded by the software solution. The various types of CE include Personal, Time Sharing, Client Server, Distributed, Cloud and Cluster. Therefore, [Contractor/Sub-Contractor] shall have the required certification for the computing environment.

3.2.2 Cybersecurity Maturity Model Certification (CMMC)

USDA SCRM Strategy applies to systems operated by USDA and entities not under the jurisdiction of the USDA Secretary that are employed or contracted to process, transmit, or store USDA information through services such as (but not limited to), platform as a service (PaaS), infrastructure as a service (IaaS), and software as a service (SaaS.). In accordance with [USDA DR 3540-003](#), The Contracting Officer Representative/Program Manager will certify that [Contractor/Sub-Contractor] has the appropriate DOD Cybersecurity Maturity Model Certification (CMMC) level as prescribed by USDA and outlined below.



3.2.3 Information Security Awareness Training

The Contracting Officer Representative/Program Manager will certify that [Contractor/Sub-Contractor] personnel have completed the required Information Security Awareness and Rules of Behavior Training prior to submission of a Security Access Requests.

4 INFORMATION AND COMMUNICATIONS TECHNOLOGY (ICT) SUPPLY CHAIN RISK MANAGEMENT (SCRM) SOFTWARE DEVELOPMENT LIFECYCLE (SDLC)

Information and Communications Technology (ICT) Supply Chain Risk Management (SCRM) Software Development Lifecycle (SDLC) is implemented as part of overall risk management activities, such as those described in [NIST SP 800-39](#), *Managing Information Security Risk*. Activities should involve identifying and assessing applicable risks, determining appropriate mitigating actions, developing an ICT SCRM Plan to document selected mitigating actions, and monitoring performance against that Plan.

[Contractor/Sub-Contractor] shall ensure the latest publication of [NIST SP 800-161](#) - *Supply Chain Risk Management Practices for Federal Information Systems and Organizations* and [NIST SP 800-37](#) - *Risk Management Framework for Information Systems and Organizations* are incorporated into their ICT SCRM SDLC process.

Consistent with the latest publication of [NIST SP 800-161](#) and [NIST SP 800-37](#), the acquisition community at the USDA and agencies will adopt an ICT SCRM SDLC approach to managing risk to information systems. The USDA, agencies, and personnel will integrate SCRM processes, activities and tasks throughout the life cycle of agency systems, components and services.

4.1 Continuous Diagnostic and Mitigation (CDM) Approved Products List (APL) Supply Chain Risk Management Plan

The Continuous Diagnostics and Mitigation (CDM) Approved Products List (APL) Product Submission Instructions reference the requirement to submit a Supply Chain Risk Management Plan (SCRM) as part of that activity. The [CDM APL SCRM Plan](#) is in support of the National Institute of Standards (NIST) and the latest publication of NIST Special Publication (SP) 800-53 “SA-12” supply chain control.

[Contractor/Sub-Contractor] is responsible for providing the CDM APL SCRM Plan. The purpose of this document is to provide background information on the SCRM requirement and outline the instructions an offeror is to follow in completing and submitting the CDM APL SCRM Plan. The CDM APL SCRM Plan consists of (1) the completed questionnaires and (2) additional information the offeror wishes to provide. APL submission packages that do not include completed CDM-APL-SCRM questionnaires will fail conformance. Additional information can be submitted; APL packages will not fail conformance for the lack of providing SCRM information beyond the questionnaires for CDM-APL-SCRM.

The objective of CDM SCRM Plan is to provide information to Agencies and ordering activities about how the offeror identifies, assesses, and mitigates supply chain risks in order to facilitate better informed decision-making by Agencies and ordering activities. The CDM SCRM Plan is intended to provide visibility into, and improve the buyer’s understanding of, how the Offeror’s proposed products are developed, integrated and deployed; as well as the processes, procedures, and practices used to assure the integrity, security, resilience, and quality of those products.

The contractor shall include a CDM SCRM Plan with its proposal that addresses counterfeit and illegally modified products. The CDM SCRM plan shall describe the contractor’s approach to SCRM and demonstrate how the contractor’s approach will reduce and mitigate supply chain risks. For additional details on GSA’s internal guidance on supply chain risk management, see subpart GSAM 504.70.

The contractor shall provide a CDM SCRM plan to manage supply chain risk throughout each of the five (5) supply chain phases specified in its proposal: 1) design and engineering, 2) manufacturing and assembly, 3) distribution and warehousing, 4) operations and support, and 5) disposal and return. In addition to the components and processes for which the contractor is directly responsible, and as feasible, the contractor shall identify “specified supporting infrastructure beyond the system boundary” and where appropriate, include such infrastructure in its SCRM Plan.

The CDM SCRM Plan shall address at a minimum, but not be limited to, the following:

1. How the contractor ensures that requirements for genuine Information Technology Tools (ITT) are imposed upon its direct suppliers, whether the direct supplier is a systems integrator, reseller or OEM. The requirements for assurance and supporting evidence must include:
 - a) The contractor performs reasonable steps to ensure its SCRM Plan is performed for ITT in its delivered and installed configuration;
 - b) Equipment resellers from whom the contractor purchases ITT have valid licenses for OEM equipment and software;
 - c) The ITT OEM exercises strict quality control to ensure that counterfeit or illegally modified hardware or software components are not incorporated into the OEM product; and

- d) The contractor ensures traceability of assurance and evidence of genuineness of ITT back to the licensed product and component OEMs.
2. The contractor's use of system security engineering processes in specifying and designing a system that is protected against external threats and against hardware and software vulnerabilities.
3. The contractor's strategy for implementing SCRM security requirements throughout the life of the contract. The SCRM plan shall address the security controls described in the latest publication of [NIST SP 800-53](#). Implementation of the controls shall be tailored in scope to the effort and the specific information.
4. The criticality analysis (CA) process used by the contractor to determine Mission Critical Functions and the protection techniques (countermeasures and sub-countermeasures) used to achieve system protection and mission effectiveness. The CA shall describe the contractor's supply chain for all critical hardware and software components (and material included in products), key suppliers, and include proof of company ownership and location (on-shore or off-shore) for key suppliers and component manufacturers.
5. How the contractor will ensure that products and components are not repaired and shipped as new products and components are provided to the government.
6. How the contractor will ensure that supply channels are monitored for counterfeit products throughout the product life cycle to include maintenance and repair.
7. How the contractor's physical and logical delivery mechanisms will protect against unauthorized access, exposure of system components, information misuse, unauthorized modification, or redirection.
8. How the contractor's operational processes (during maintenance, upgrade, patching, element replacement, or other sustainment activities) and disposal processes will limit opportunities for knowledge exposure, data release, or system compromise.
9. Which of the following identifies the relationship between the contractor and the manufacturer:
1) OEM, 2) authorized reseller, 3) authorized partner/distributor, or 4) unknown/unidentified source.
10. How the contractor will ensure independent verification and validation of assurances, and provide supporting evidence as required.

[NIST SP 800-161](#) identifies supply chain risk management (SCRM) best practices. The offeror shall update its SCRM Plan to include any future changes to the NIST SCRM Guidelines and all such modifications to the Plan shall be made at no cost to the government.

4.2 SCRM Plan Submittal and Review

The plan shall be submitted with the contractor's proposal. Updates shall be submitted on an annual basis to the CO and COR. All information included will be treated as Controlled Unclassified Information (CUI) pursuant to Executive Order 13556, shared only with government agencies, and used solely for the

purposes of mission-essential risk management. All reviews shall be completed within a 45-day time period.

4.3 Manufacturing (Original Equipment Manufacturer (OEM))

[Contractor/Sub-Contractor] developers shall perform industry best practices associated with security testing and evaluation consistent with the latest publication of [Special Publication 800-115 - Technical Guide to Information Security Testing and Assessment](#). This includes, but is not limited to, the following:

- Implement a repeatable and documented assessment methodology;
- Analyze findings, and develop risk mitigation techniques to address weaknesses;
- Provide consistency and structure to security testing, which can minimize testing risks; and
- Address resource constraints associated with security assessments.

4.3.1 Counterfeit Parts/Replacement Parts

A product is genuine if it is not counterfeited, imitated, tampered or adulterated and is not gray market, remanufactured, or refurbished. [Contractor/Sub-Contractor] shall report all suspected counterfeit material/items to the Government through the Government Industry Data Exchange Program (GIDEP) database and to the program office via e-mail to the Contracting Officer, Program Manager, and COR within # working days of discovery. The [Contractor/Sub-Contractor] shall prominently label all suspected counterfeit material/items and physically separate from all other supplies and shall not return or dispose suspected or confirmed counterfeit material/items to the supplier but hold such items for Government analysis and investigation. The [Contractor/Sub-Contractor] shall aid the Government investigation including providing all documents associated with the purchase, shipping, and other relevant data on the counterfeit materials/items. The Government will provide final disposition instructions for confirmed counterfeit material/items to include turnover to the Government.

4.4 End of Life/Support Products

Any product within 18 months of End of Life/End of Support will not be procured by USDA.

4.4.1 Product Integrity [GSA SECTION 846 – COUNTERFEIT ITEMS]

4.4.1.1 Hardware, Software, and Patch Integrity and Authenticity:

If [Contractor/Sub-Contractor] provides software or patches to USDA, [Contractor/Sub-Contractor] shall publish or provide a hash conforming to the Federal Information Processing Standard (FIPS) Security Requirements for Cryptographic Modules (FIPS 140-2) or similar standard information on the software and patches to enable USDA to use the hash value as a checksum to independently verify the integrity of the software and patches and avoid downloading the software or patches from [Contractor/Sub-Contractor]'s website that has been surreptitiously infected with a virus or otherwise corrupted without the knowledge of [Contractor/Sub-Contractor].

- a) [Contractor/Sub-Contractor] is responsible for providing software that is free of vulnerabilities by validating that those Common Vulnerability and Exposures (CVE), common weakness enumeration (CWE);

- b) Open Web Application Security Project (OWASP) items that are most dangerous to the mission are absent from the software and that the software operates at the least privilege required to complete its task; and
- c) [Contractor/Sub-Contractor] shall establish, document, and implement risk management practices for supply chain delivery of hardware, software (including patches), and firmware provided under this Agreement.

4.4.1.2 *Digital Delivery*

[Contractor/Sub-Contractor] shall specify how digital delivery for procured products (*e.g.*, software, applications, and data) including patches will be validated and monitored to ensure the digital delivery remains as specified. If USDA deems that it is warranted, [Contractor/Sub-Contractor] shall apply encryption to protect procured products throughout the delivery process.

4.4.1.3 *Firmware*

- a) Prior to the delivery of any products and services to USDA or any connection of electronic devices, assets or equipment to USDA's electronic equipment, [Contractor/Sub-Contractor] shall provide documentation regarding its patch management and vulnerability management and continuous monitoring (including third-party hardware, software, and firmware) for products, services, and any electronic device, asset, or equipment required to be connected to the assets of USDA during the provision of products and services under this Agreement. This documentation shall include information regarding:
 - Resources and technical capabilities to sustain this program and process such as [Contractor/Sub-Contractor]'s method or recommendation for how the integrity of a patch is validated by USDA;
 - [Contractor/Sub-Contractor] procedures to Check Software and the patches for authenticity and integrity of the products with integrity verification tools, to detect unauthorized changes to software, information system and the supply chain. An example of a validation procedure may be the use of digital signature by an OEM to prove that the software delivered is from its originating source. When digital signatures are used for this purpose, the organization should ensure, when receiving such software, that the signed upgrade/download was not altered;
 - USDA will ensure that code authentication mechanisms such as digital signature, certificate is recognized and approved;
 - Implement the use of cryptographic mechanisms, to authenticate software, hardware, information systems within the supply chain infrastructure;
 - [Contractor/Sub-Contractor]'s approach and capability to remediate newly reported zero-day vulnerabilities; and
 - [Contractor/Sub-Contractor] shall ensure all developers are trained and held accountable for development of secure code.
- b) Unless otherwise approved by the USDA in writing, current or supported version of [Contractor/Sub-Contractor] products and services shall not require the use of out-of-date, unsupported, or end-of-life version of third-party components (*e.g.*, Java, Flash, Web browser, etc.).

- c) [Contractor/Sub-Contractor] shall verify and provide documentation that procured products (including third-party hardware, software, firmware, and services) have appropriate updates and patches installed prior to delivery to USDA.
- d) In providing the products and services described in this Agreement [Contractor/Sub-Contractor] shall provide appropriate software and firmware updates to remediate newly discovered vulnerabilities or weaknesses within [a negotiated time period]. Updates to remediate critical vulnerabilities shall be provided within a shorter period than other updates, within *14 days*. If updates cannot be made available by [Contractor/Sub-Contractor] within these time periods, [Contractor/Sub-Contractor] shall provide mitigations within a negotiated time period.
- e) When third-party hardware, software (including open-source software), and firmware is provided by [Contractor/Sub-Contractor] to USDA, [Contractor/Sub-Contractor] shall provide appropriate hardware, software, and firmware updates to remediate newly discovered vulnerabilities or weaknesses within [a negotiated time period]. Updates to remediate critical vulnerabilities shall be provided within a shorter period than other updates, within *14 days*. If these third-party updates cannot be made available by [Contractor/Sub-Contractor] within these time periods, [Contractor/Sub-Contractor] shall provide mitigations within a negotiated time period.

4.4.2 Viruses and Malware

[Contractor/Sub-Contractor] will use reasonable efforts to investigate whether computer viruses or malware is present in any software or patches before providing such software or patches to USDA.

- a) [Contractor/Sub-Contractor] warrants that it has no knowledge of any computer viruses or malware coded or introduced into any software or patches, and [Contractor/Sub-Contractor] will not insert any code which would have the effect of disabling or otherwise shutting down all or a portion of such software or damaging information or functionality.
- b) When installed files, scripts, firmware, or other [Contractor/Sub-Contractor] deliverer software solutions are flagged as malicious, infected, or suspicious by an anti-virus vendor through open source solutions, [Contractor/Sub-Contractor] must provide technical proof as to why the “false positive” hit has taken place to ensure their code’s supply chain has not been compromised.
- c) If a virus or other malware is found to have been coded or otherwise introduced as a result of [Contractor/Sub-Contractor]’s breach of its obligations under this Agreement, [Contractor/Sub-Contractor] shall immediately and at its own cost:
 - Take all necessary remedial action and provide assistance to USDA to eliminate the virus or other malware throughout USDA’s information networks, computer systems, and information systems, regardless of whether such systems or networks are operated by or on behalf of USDA; and
 - If the virus or other malware causes a loss of operational efficiency or any loss of data (A) where [Contractor/Sub-Contractor] is obligated under this Agreement to back up such data, take all steps necessary and provide all assistance required by USDA and its affiliates, and (B) where [Contractor/Sub-Contractor] is not obligated under this Agreement to back up such data, use commercially reasonable efforts, in each case to mitigate the loss of or damage to such data and to restore the efficiency of such data.

4.5 Transport/Shipping

4.5.1 Chain of Custody

Chain of Custody apply throughout the ICT SCRM SDLC phases; therefore, refer to [Section 5.1 – Chain of Custody](#).

4.5.2 Anti-Tamper Testing/Inspection

Tamper Resistance and Detection apply throughout the ICT SCRM SDLC phases; therefore, refer to [Section 5.2 – Anti-Tamper and Detection](#).

4.6 Pre-Deployment

4.6.1 Chain of Custody

Chain of Custody apply throughout the ICT SCRM SDLC phases; therefore, refer to [Section 5.1 – Chain of Custody](#).

4.6.2 Anti-Tamper Testing/Inspection

Tamper Resistance and Detection apply throughout the ICT SCRM SDLC phases; therefore, refer to [Section 5.2 – Anti-Tamper and Detection](#).

4.6.3 Scanning/Malicious code (Optical Media/SW/Scan Info Systems)

[Contractor/Sub-Contractor] will use reasonable efforts to investigate whether computer viruses or malware is present in any software or patches before providing such software or patches to USDA. Refer to [Section 4.2.2 - Viruses and Malware](#).

4.7 Deployment

4.7.1 System Configuration

[Contractor/Sub-Contractor] is responsible for system configuration (i.e. System hardening) and must be in compliance with the [USDA C2 level](#) of security (based on the NSA Trusted Computer Security Evaluation Criteria) for all USDA IT Systems. System hardening, or C2, as defined by the NSA, includes making specific modifications to an operating system before it is put into use in order to aid in the reduction of operating risks and to increase system availability, confidentiality and integrity. In addition [Contractor/Sub-Contractor] will comply to [DISA Security Technical Implementation Guide \(STIG\)](#).

4.8 Operation and Maintenance

4.8.1 Continuous Monitoring

[Contractor/Sub-Contractor] will provide ongoing agency system security, vulnerability, and threat awareness to USDA in accordance with Risk Management Framework (RMF) process. Continuous monitor and support agency IT system Authorization to Operate (ATO) submissions. Monitor IT network, information, and system security. [Contractor/Sub-Contractor]'s continuous monitoring practices shall be in compliance with [USDA DR 3505-005 - Cybersecurity Incident Management](#).

4.9 Return USDA Government Furnished Property

4.9.1 Chain of Custody

Chain of Custody apply throughout the ICT SCRM SDLC phases; therefore, refer to [Section 5.1 – Chain of Custody](#).

4.9.2 Anti-Tamper Testing/Inspection

Tamper Resistance and Detection apply throughout the ICT SCRM SDLC phases; therefore, refer to [Section 5.2 – Anti-Tamper and Detection](#).

4.9.3 Return of Government Furnished Property

Government furnished property (GFP) is property that is furnished to a contractor for performance of a USDA contract. There are two types of Government Furnished Property: Equipment and Material. Upon completion of the contract, [Contract/Vendor] is required to follow return of GFP in accordance with the latest publication of [NIST 800-88 - Guidelines for Media Sanitization](#) and compliance in with best industry practices such as [Department of Defense 5220-22-M Standard - National Industrial Security Program \(NISP\)](#).

Upon completion of the delivery of the products and services to be provided under this Agreement, or at any time upon USDA's request, [Contractor/Sub-Contractor] will return to USDA all hardware and removable media provided by USDA containing USDA Information. USDA Information in returned hardware and removable media shall not be removed or altered in any way. The hardware should be physically sealed and returned via a bonded courier or as otherwise directed by USDA. If the hardware or removable media containing USDA Information is owned by [Contractor/Sub-Contractor] or a third-party, a notarized statement detailing the destruction method used and the data sets involved, the date of destruction, and the entity or individual who performed the destruction will be sent to a designated USDA security representative within fifteen (15) calendar days after completion of the delivery of the products and services to be provided under this Agreement, or at any time upon USDA's request. [Contractor/Sub-Contractor]'s destruction or erasure of USDA Information pursuant to this Section shall comply with best industry practices (*e.g.*, Department of Defense 5220-22-M Standard, as may be amended). USDA will determine future disposition of government furnished equipment (*i.e.* disposal, recycle).

5 ALL-INCLUSIVE AREAS WITHIN ICT SCRM SDLC

This section contains activities that apply throughout the ICT SCRM SDLC; therefore [Contractor/Sub-Contractor] are to adhere to the all-inclusive areas without exception.

5.1 Chain of Custody

[Contractor/Sub-Contractor] is responsible for the end-to-end visibility and sensor technology that enables 24-7 monitoring of cargo which includes who touched it at either end; whether the cargo has deviated from its designated route; or whether the container or package has been opened in route. Sensors provide information on cargo conditions such as shock detectors, temperature, humidity, etc. These types of asset visibility measures safeguard both the physical security and quality of the shipment.

5.2 Tamper Resistance and Detection

[Contractor/Sub-Contractor] shall use a combination of hardware and software techniques for tamper resistance and detection. These techniques should include but not limited to obfuscation and self-checking to make reverse engineering and modifications more difficult, time-consuming, and expensive for adversaries. Strong identification combined with tamper resistance and/or tamper detection is essential to protecting information systems, components, and products during distribution and when in use.

5.3 Incidents

5.3.1 Vendor Identified Incidents

Whenever a security incident occurs, [Contractor/Sub-Contractor] agrees to notify USDA within # by telephone and email, and subsequently via written correspondence or form.

5.3.2 Incident Response

Upon any cyber incident, [Contractor/Sub-Contractor] will adhere to [USDA DR 3505-005 - Cybersecurity Incident Management](#).

Within # days of notifying USDA of the security incident, [Contractor/Sub-Contractor] shall recommend actions to be taken by USDA on USDA-controlled systems to reduce the risk of a recurrence of the same or a similar security incident, including, as appropriate, the provision of action plans and mitigating controls. [Contractor/Sub-Contractor] shall coordinate with USDA in developing those action plans and mitigating controls. [Contractor/Sub-Contractor] will provide USDA guidance and recommendations for long term remediation of any cybersecurity risks posed to USDA information, equipment, systems, and networks as well as any information necessary to assist USDA in any recovery efforts undertaken by USDA in response to the security incident.

5.3.3 Development and Implementation of a Response Plan

[Contractor/Sub-Contractor] shall develop and implement policies and procedures to address security incidents ("Response Plan") by mitigating the harmful effects of security incidents and remedying the occurrence to prevent the recurrence of security incidents in the future.

[Contractor/Sub-Contractor] shall provide USDA access to inspect its Response Plan. The development and implementation of the Response Plan shall follow best practices that at a minimum are consistent with the contingency planning requirements of the latest publication:

- NIST Special Publication 800-61 Rev. 2, Computer Security Incident Handling Guide
- NIST Special Publication 800-53 Rev. 4, Security and Privacy Controls for Federal Information Systems and Organizations
 - CP-1 through CP-137
 - IR-1 through IR-10

Immediately upon learning of a security incident related to the products and services provided to USDA, [Contractor/Sub-Contractor] shall implement its Response Plan and within 24 hours of implementing its Response Plan, shall notify USDA.

5.3.4 Prevention of Recurrence:

Within # days of a security incident, [Contractor/Sub-Contractor] shall develop and execute a plan that reduces the likelihood of the same or a similar security incident from occurring in the future consistent with the requirements of its Response Plan and NIST Special Publication 800-61rev2 and NIST Special Publication 800-184, Guide for Cybersecurity Event Recovery (as may be amended) and shall communicate that plan to USDA. [Contractor/Sub-Contractor] shall provide recommendations to USDA on actions that USDA may take to assist in the prevention of recurrence, as applicable or appropriate.

5.3.5 Customer Notification (CN):

[Contractor/Sub-Contractor] will, at its sole cost and expense, assist and cooperate with USDA with respect to any investigation of a security incident, critical and high vulnerabilities and product flaws, disclosures to affected parties, and other remedial measures as requested by USDA in connection with a security incident or required under any applicable laws related to a Security Incident.

In the event a Security Incident results in USDA information being disclosed such that notification is required to be made to any person or entity, including without limitation any customer, shareholder, or current or former employee of USDA under any applicable laws, including privacy and consumer protection laws, or pursuant to a request or directive from a governmental authority, such notification will be provided by USDA, except as required by applicable law or approved by USDA in writing. USDA will have sole control over the timing and method of providing such notification.

5.4 Vulnerabilities

5.4.1 Disclosure and Remediation of Known Vulnerabilities by Vendor

[Contractor/Sub-Contractor] shall develop and implement policies and procedures to address the disclosure and remediation by [Contractor/Sub-Contractor] of vulnerabilities and material defects related to the products and services provided to USDA under this Agreement including the following:

- (a) Prior to the delivery of the procured product or service, [Contractor/Sub-Contractor] shall provide summary documentation of publicly disclosed vulnerabilities and material defects related in the procured product or services, the potential impact of such vulnerabilities and material defects, the status of [Contractor/Sub-Contractor]'s efforts to mitigate those publicly disclosed vulnerabilities and material defects, and [Contractor/Sub-Contractor]'s recommended corrective actions, compensating security controls, mitigations, and/or procedural workarounds.
- (b) [Contractor/Sub-Contractor] shall provide summary documentation of vulnerabilities and material defects in the procured product or services within thirty (30) calendar days after such vulnerabilities and material defects become known to [Contractor/Sub-Contractor]. This includes summary documentation on vulnerabilities that have not been publicly disclosed or have only been identified after the delivery of the product. The summary documentation shall include a description of each vulnerability and material defects and its

potential impact, root cause, and recommended corrective actions, compensating security controls, mitigations, and/or procedural workarounds.

- (c) [Contractor/Sub-Contractor] shall disclose the existence of all known methods for bypassing computer authentication in the procured product or services, often referred to as backdoors, and provide written documentation that all such backdoors created by [Contractor/Sub-Contractor] have been permanently deleted or disabled.
- (d) [Contractor/Sub-Contractor] shall implement a vulnerability detection and remediation program consistent with the latest publication of NIST Special Publication 800-53 RA-5,18 SA-11/19 and SI-2 (as may be amended).

5.5 USDA's Audit Rights

USDA or its third-party designee may, but is not obligated to, perform audits and security tests of [Contractor/Sub-Contractor]'s IT or systems environment and procedural controls to determine [Contractor/Sub-Contractor]'s compliance with the system, network, data, and information security requirements of this Agreement. These audits and tests may include coordinated security tests, interviews of relevant personnel, review of documentation, and technical inspection of systems and networks as they relate to the receipt, maintenance, use, retention, and authorized destruction of USDA Information. [Contractor/Sub-Contractor] shall provide all information reasonably requested by USDA in connection with any such audits and shall provide reasonable access and assistance to USDA upon request. [Contractor/Sub-Contractor] will comply, within reasonable timeframes at its own cost and expense, with all reasonable recommendations that result from such inspections, tests, and audits. USDA reserves the right to view, upon request, any original security reports that [Contractor/Sub-Contractor] has undertaken or commissioned to assess [Contractor/Sub-Contractor]'s own network security. If requested, copies of these reports will be sent via bonded courier to USDA security contact. [Contractor/Sub-Contractor] will notify USDA of any such security reports or similar assessments once they have been completed. Any regulators of USDA or its affiliates shall have the same rights of audit as described herein upon request.

Evidence of compliance or successful documented operational implementation can be in the form of inspection/audit results, or artifacts related to applicable Supply Chain or Information Security Management System certifications (e.g. O-TTPS/ISO 20243:2018), or internal SCRM program test/inspection results related to quality, security, or supplier management programs.

5.6 Covered Telecommunication Equipment or Services (Section 889(a)(1)(B))

In support of FAR Case 2019-009 on Section 889(a)(1)(B) of the John S. McCain National Defense Authorization Act (NDAA) commonly referred to as "Section 889 Part":

If the contractor confirms that it identified prohibited telecom used during contract performance and an existing waiver does not apply, the CO shall submit a Supply Chain Event Report to the SCRM Review Board, including, at a minimum:

- (1) A "critical date", no less than three business days, for when a response from the SCRM Review Board is requested. The CO may proceed to the next step(s) below if the SCRM Review Board has not responded by the "critical date".
- (2) The information provided by the offeror under paragraph (d) of the reporting clause at FAR 52.204-25.

- (3) Be aware that the SCRM Review Board may ask for additional information.

5.6.1 Identified Prohibited Telecom

If the contractor confirms that it identified prohibited telecom used during contract performance and there is no applicable waiver, the CO will need to determine whether or not an exception applies, if the prohibited telecom is not a substantial or essential component of a system, or if the prohibited telecom is not critical technology as part of any system.

- (1) The SCRM Review Board will provide to the CO, via response to the Supply Chain Event Report, information as to whether it thinks that continued performance or extension of the contract (or order) will result in a violation of the prohibition. If the SCRM Review Board has not responded by the “critical date”, the CO may decide without the SCRM Review Board’s input.
- (2) Resources for assisting the CO in making this determination, based on previous guidance provided by GSA’s SCRM Review Board, will be available on the Acquisition Portal at <http://insite.gsa.gov/scrm>.
- (3) If, after using such resources, the CO cannot make this determination on their own, the CO should consult with their acquisition team, technical experts, their management, and request additional assistance from the SCRM Review Board by contacting SCRM-Review-Board@gsa.gov.
- (4) If the CO determines that continued performance or extension of the contract (or order) will not result in a violation of the prohibition, the CO should document the file accordingly and may continue performance of and/or extend the contract (or order).

5.6.2 Exceptions Clarification

The statute includes two exceptions at 889 (a)(2)(A) and (B). (1) The exception at 889(a)(2)(A) allows the head of executive agency to procure with an entity “to provide a service that connects to the facilities of a third-party, such as backhaul, roaming, or interconnection arrangements”. (2) The exception at 889(a)(2)(B) allows an entity to procure “telecommunications equipment that cannot route or redirect user data traffic or [cannot] permit visibility into any user data or packets that such equipment transmits or otherwise handles.” **The exception allowing for procurement of services that connect to the facilities of a third-party, such as backhaul, roaming, or interconnection arrangements applies only to a Government agency that is contracting with an entity to provide a service. Therefore, the exception does not apply to a contractor’s use of a service that connects to the facilities of a third-party, such as backhaul, roaming, or interconnection arrangements.** As a result, the Federal Government is prohibited from contracting with a contractor that uses covered telecommunications equipment or services to obtain backhaul services from an internet service provider, unless a waiver is granted.

5.7 Environmental Risks

Without proper risk aversion strategies, the supply chains can be disrupted by environmental factors; therefore, all the environment-related legislation made by governments and other regulatory bodies should be followed.

Negative environmental impacts such as carbon emissions can be reduced; waste must be disposed of properly; and chemicals handled properly to protect the environment. To avoid the dangers of natural disasters, [Contractor/Sub-Contractor] must choose their location and mode of transport strategically. They should be flexible and responsive enough to absorb changes and capable enough to avoid any distortions in the supply chain.

6 APPENDICES

6.1 [Contractor/Sub-Contractor] Cybersecurity Policy / System Security Plan

[Contractor/Sub-Contractor] Cybersecurity Policy or System Security Plan: [Contractor/Sub-Contractor] will provide to USDA the [Contractor/Sub-Contractor]'s [Contractor/Sub-Contractor] Cybersecurity Policy or System Security Plan: [Contractor/Sub-Contractor] will provide to USDA the [Contractor/Sub-Contractor]'s cybersecurity policy, which shall be consistent with the latest publication of NIST Special Publications (SP) 800-39, NIST SP 800-37 , as may be amended. [Contractor/Sub-Contractor] will implement and comply with that cybersecurity policy.

The System Security Plan (SSP) contains information that is deemed non-disclosure, it contains the security posture of the system, the system diagrams, system interconnects, Topologies, System boundaries and all implemented and future controls to be implemented. It must be secured with enhancements.

Cybersecurity policy, which shall be consistent with the latest publication of NIST Special Publication 800-53, 800-37, 800-39 as may be amended. [Contractor/Sub-Contractor] will implement and comply with that cybersecurity policy. Any changes to [Contractor/Sub-Contractor]'s cybersecurity policy as applied to products and services provided to USDA under this Agreement and USDA Information that are inconsistent with the security requirements of the latest publication of NIST Special Publication 800-53 as may be amended shall be subject to review and approval by USDA prior to implementation by [Contractor/Sub-Contractor].

6.2 Cybersecurity & Supply Chain Risk Management (SCRM) References

[Contractors/Sub-Contractors] entering into an agreement to provide service to Government activities are subject to cybersecurity and SCRM laws, regulations, standards, policies and reporting requirements. Additional and/or tailored cybersecurity and SCRM requirements may be included in individual Task Orders by the issuing agency OCO. The [Contractor/Sub-Contractor] shall ensure all applicable Commercial-Off-The-Shelf (COTS) and enabled products comply with ordering agency cybersecurity and SCRM requirements.

a) Laws

- The Clinger-Cohen Act of 1996, Pub. L. 104-106, Division E
- The Federal Information Security Modernization Act of 2014, Pub. L. 113-283
- Federal Information Technology Acquisition Reform Act (FITARA), Pub. L.113-291
- The SECURE Technology Act, Pub. L.115-390

b) Executive Orders

- Executive Order 13859, Maintaining American Leadership in Artificial Intelligence
- Executive Order 13873, Securing the Information and Communications Technology and Services Supply Chain
- Executive Order 13833, Enhancing Effectiveness of Agency Chief Information Officers
- Executive Order 13800, Strengthening the Cybersecurity of Federal Networks and Critical Infrastructure
- Executive Order 13870, America's Cybersecurity Workforce

c) Policies of the Committee on National Security Systems

- The policies presented under this topic address national security systems issues from a broad perspective. They establish national-level goals and objectives, all of which are binding upon all U.S. Government departments and agencies.
 - <http://www.cnss.gov/CNSS/issuances/Policies.cfm>
- d) OMB Circulars and Memoranda
 - Circulars (<https://www.whitehouse.gov/omb/information-for-agencies/circulars/>)
 - A-130
 - A-123
 - A-108
 - A-11
 - Memoranda (<https://www.whitehouse.gov/omb/information-for-agencies/memoranda/>)
 - M-19-18
 - M-19-17
 - M-19-03
 - M-19-02
 - M-19-01
 - M-18-23
 - M-18-12
 - M-17-25
 - M-16-04
 - M-15-14
- e) National Institute of Standards and Technology (NIST)
 - Federal Information Processing Standards (FIPS)
 - <https://www.nist.gov/itl/fips-general-information>
 - <https://www.nist.gov/standardsgov/compliance-faqs-federal-information-processingstandards-fips>
 - Special Publication 800-series and 1800-series
 - <https://www.nist.gov/itl/nist-special-publication-800-series-general-information>
 - <https://csrc.nist.gov/publications/sp800>
 - <https://www.nist.gov/itl/nist-special-publication-1800-series-general-information>
 - <https://csrc.nist.gov/publications/sp1800>
 - Framework for Improving Critical Infrastructure Cybersecurity
 - <https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.04162018.pdf>
 - NICE Cybersecurity Workforce Framework Resource Center
 - <https://www.nist.gov/itl/applied-cybersecurity/nice/nice-cybersecurity-workforceframework-resource-center>
- f) Cybersecurity and Infrastructure Security Agency
 - [Information and Communications Technology Supply Chain Risk Management](#)
- g) Cybersecurity Maturity Model Certification

- Cybersecurity Maturity Model Certification (CMMC)
- CMMC Accreditation Body
- a) National Defense Authorization Act of 2019
 - Section 881: Permanent Supply Chain Risk Management Authority
 - Section 889: Prohibition on certain telecommunications and video surveillance services or
 - equipment (FAR 52.204-24 and FAR 52.204-25)
 - Sections 1631-1657: Cyber-spaced Related Matters

6.3 DEFINITIONS

Common definitions are provided below. For references to additional definitions, refer to www.Lexicon.com.

Company Information means for purposes of these terms and conditions, any and all information concerning USDA and its business in any form, including, without limitation, the products and services provided under this Agreement that is disclosed to or otherwise learned by [Contractor/Sub-Contractor] during the performance of this Agreement.
Company means the organization that acquires or procures a product or service.
Counterfeit electronic part means an unlawful or unauthorized reproduction, substitution, or alteration that has been knowingly mismarked, misidentified, or otherwise misrepresented to be an authentic, unmodified electronic part from the original manufacturer, or a source with the express written authority of the original manufacturer or current design activity, including an authorized aftermarket manufacturer. Unlawful or unauthorized substitution includes used electronic parts represented as new, or the false identification of grade, serial number, lot number, date code, or performance characteristics.
Disclosed means any circumstance when the security, integrity, or confidentiality of any USDA Information has been compromised, including but not limited to incidents where USDA Information has been damaged, lost, corrupted, destroyed, or accessed, acquired, modified, used, or disclosed by any unauthorized person, by any person in an unauthorized manner, or for an unauthorized purpose.
Electronic part means an integrated circuit, a discrete electronic component (including, but not limited to, a transistor, capacitor, resistor, or diode), or a circuit assembly (section 818(f)(2) of Pub. L. 112-81).
Government Furnished Equipment (GFE) - Government furnished equipment or "GFE" consists of equipment, special tooling, or special test equipment that is provided to a contractor for use on a Government contract (reference Federal Acquisition Regulations, Part 45).
Government Furnished Material (GFM) - Government furnished material (GFM) is another form of Government-owned property that is sometimes provided to contractors. Raw titanium for use in ship construction, nuts, bolts, washers, screws, and other consumable items are all examples of GFM. Material does not include equipment, special tooling, and special test equipment.
Hash - The hash is used to verify that data is not modified, tampered with, or corrupted. In other words, you can verify the data has maintained integrity.
Obsolete electronic part means an electronic part that is no longer available from the original manufacturer or an authorized aftermarket manufacturer.
Original component manufacturer means an organization that designs and/or engineers a part and is entitled to any intellectual property rights to that part.

Original equipment manufacturer means a company that manufactures products that it has designed from purchased components and sells those products under the company's brand name.
Original manufacturer means the original component manufacturer, the original equipment manufacturer, or the contract manufacturer.
Security Incident means any circumstance when (i) [Contractor/Sub-Contractor] knows or reasonably believes that USDA Information hosted or stored by the [Contractor/Sub-Contractor] has been disclosed; (ii) [Contractor/Sub-Contractor] knows or reasonably believes that an act or omission has compromised or may reasonably compromise the cybersecurity of the products and services provided to USDA by [Contractor/Sub-Contractor] or the physical, technical, administrative, or organizational safeguards protecting [Contractor/Sub-Contractor]'s systems or USDA's systems storing or hosting USDA Information; or (iii) [Contractor/Sub-Contractor] receives any complaint, notice, or communication which relates directly or indirectly to (A) [Contractor/Sub-Contractor]'s handling of USDA Information or [Contractor/Sub-Contractor]'s compliance with the data safeguards in this Agreement or applicable law in connection with USDA Information or (B) the cybersecurity of the products and services provided to USDA by [Contractor/Sub-Contractor].
Security Technical Implementation Guide (STIG) is a cybersecurity methodology for standardizing security protocols within networks, servers, computers, and logical designs to enhance overall security.
Supply Chain Risk Management (SCRM) means a systematic process for managing supply chain risk by identifying susceptibilities, vulnerabilities, and threats throughout the supply chain and developing mitigation strategies to combat those threats whether presented by the supplier, the supplied product and its sub-elements, or the supply chain (e.g., initial production, packaging, handling, storage, transport, mission operation, and disposal). CNNSD 50, SCRM
Supply Chain Risk means that an adversary may sabotage, maliciously introduce unwanted function, or otherwise subvert the design, integrity, manufacturing, production, distribution, installation, operation, or maintenance of an item of supply or a system to surveil, deny, disrupt, or otherwise degrade the function, use, or operation of a system (The Ike Skelton National Defense Authorization Act for Fiscal Year 2011, Section 806).
Suspect counterfeit electronic part means an electronic part for which credible evidence (including, but not limited to, visual inspection or testing) provides reasonable doubt that the electronic part is authentic.

6.4 Acronyms and Abbreviations

A&A	Assessment and Authorization
APL	Approved Product List
ATO	Authorization to Operate
CDM	Continuous Diagnostics and Monitoring
COR	Contracting Officer's Representative
COTS	Commercial Off-the-Shelf
CP	Contingency Plan
CUI	Controlled Unclassified Information
CWE	Common Weakness Enumeration
DISA	Defense Information Systems Agency
DOD	Department of Defense
DR	Departmental Regulation
FAR	Federal Acquisition Regulation
FIPS	Federal Information Processing Standards
FITARA	Federal Information Technology Acquisition Reform Act
FOCI	Foreign Ownership Control or Influence
GFE	Government-Furnished Equipment
GSA	General Services Administration
HSPD	Homeland Security Presidential Directive
IaaS	Infrastructure as a Service
ICT	Information and Communications Technology
ISC	Information Security Center
IT	Information Technology
NACI	National Agency Check with Written Inquiries
NDAA	National Defense Authorization Act
NICE	National Initiative for Cybersecurity Education
NISP	National Industrial Security Program
NIST	National Institute of Standards and Technology

NS	National Security
NSA	National Security Agency
OCIO	Office of the Chief Information Officer
OMB	Office of Management and Budget
OPM	Office of Personnel Management
OWASP	Open Web Application Security Project
PaaS	Platform as a Service
PDF	Portable Document Format
PIV	Personal Identity Verification
RMF	Risk Management Framework
SaaS	Software as a Service
SCRM	Supply Chain Risk Management
SDLC	Software Development Lifecycle
SOW	Statement of Work
SP	Special Publication
SSP	System Security Plan
STIG	Security Technical Implementation Guide
USDA	United States Department of Agriculture